

DNSenum

1. 개념

: 칼리리눅스에 내장된 **DNS**정보 수집 올인원 도구

: **Zone Transfer(AXFR)**와 **Subdomain Enumeration** 기능 모두 수행 가능

2. 작동 원리

a. 기본 정보 수집

: 대상도메인의 **A**레코드(IP), **NS**, **MX**(메일서버)정보 조회

b. Zone transfer 시도 (AXFR check)

: 윗단계에서 찾아낸 모든 네임서버를 대상으로 **zone transfer** 취약점이 있는지 자동으로 확인하고 성공하면 모든 목록을 가져옴

c. 구글 검색엔진 이용하여 해당 도메인의 서브도메인이 인덱싱 되어있는지 긁어옴 (검색쿼리를 자동으로 날림)

d. 사전파일 대입

: 내장된 단어장을 활용하여 **DNS** 쿼리를 계속 날려보고 응답이 오면 표시함

e. Reverse Lookup으로 IP대역 조회

: 찾아낸 **IP** 주소대역(**C class**) 전체를 스캔하여 해당 네트워크 대역에 연관된 다른 도메인이 있는지 역방향 조회 수행

3. 자주쓰이는 옵션

옵션	설명	사용예시
<code>--enum</code>	가장 많이 사용. 자주 쓰이는 옵션들을 한 번에 실행하는 단축 옵션(기본 조회, 존 전송, 구글 스크래핑 등 포함)	<code>dnsenum --enum example.com</code>
<code>-f [파일경로]</code>	서브도메인 브루트 포스에 사용할 사전 파일을 지정	<code>dnsenum -f /usr/share/wordlists/dnsmap.txt example.com</code>
<code>-r</code>	재귀(Recursion) 검색. 찾은 서브도메인의 또 다른 서브도메인까지 검색	<code>dnsenum -r --threads 10 -f /usr/share/wordlists/dnsmap.txt example.com</code>
<code>--noreverse</code>	역방향 조회(Reverse Lookup) 과정을 스킵 (시간 절약용)	<code>dnsenum --enum --noreverse -o output.xml example.com</code>
<code>-o [파일경로]</code>	결과를 XML 형식으로 저장	
<code>--threads [숫자]</code>	브루트 포스 시 사용할 스레드 개수를 지정 (속도 향상)	

4. 실습

칼리 리눅스 > dnsenum 검색 > 프로그램 실행 > cmd창 open

1) 자동 스캔

명령어 : dnsenum woo.com

옵션 : -o [파일명] ->

[파일명]으로 저장

```
└─$ dnsenum woo.com
dnsenum VERSION:1.3.1

┌─── woo.com ──┐

Host's addresses:
┌──────────┴──────────┐
woo.com.      86400    IN    A      172.16.27.100

Name Servers:
┌──────────┴──────────┐
ns.woo.com.   86400    IN    A      172.16.27.100

Mail (MX) Servers:
┌──────────┴──────────┐

Trying Zone Transfers and getting Bind Versions:
┌──────────┴──────────┐

Trying Zone Transfer for woo.com on ns.woo.com ...
woo.com.      86400    IN    SOA      (
woo.com.      86400    IN    NS       ns.woo.com.
woo.com.      86400    IN    A        172.16.27.100
woo.com.      86400    IN    AAAA     ::1
ftp.woo.com.  86400    IN    A        172.16.27.100
jl.woo.com.   86400    IN    A        172.16.27.100
ns.woo.com.   86400    IN    A        172.16.27.100
wp.woo.com.   86400    IN    A        172.16.27.100
ww1.woo.com.  86400    IN    A        172.16.27.100
ww2.woo.com.  86400    IN    A        172.16.27.100
```

2) 사전대입공격 `dnsenum --enum -f /usr/share/dnsenum/dns.txt woo.com`

-f (File 경로로)

/usr/share/dnsenum/dns.txt: 그 파일은 바로 칼리 리눅스에 기본으로 내장된 단어장(Dictionary)

```
(kali@kali)-[~]
$ dnsenum --enum -f /usr/share/dnsenum/dns.txt woo.com
dnsenum VERSION:1.3.1

----- woo.com -----

Host's addresses:
-----
woo.com. 86400 IN A 172.16.27.100

Name Servers:
-----
ns.woo.com. 86400 IN A 172.16.27.100

Mail (MX) Servers:
-----

Trying Zone Transfers and getting Bind Versions:
-----

Trying Zone Transfer for woo.com on ns.woo.com ...
woo.com. 86400 IN SOA (
woo.com. 86400 IN NS ns.woo.com.
woo.com. 86400 IN A 172.16.27.100
woo.com. 86400 IN AAAA ::1
ftp.woo.com. 86400 IN A 172.16.27.100
jl.woo.com. 86400 IN A 172.16.27.100
ns.woo.com. 86400 IN A 172.16.27.100
wp.woo.com. 86400 IN A 172.16.27.100
ww1.woo.com. 86400 IN A 172.16.27.100
ww2.woo.com. 86400 IN A 172.16.27.100
```

=> ftp, wp, jl과 같은 내부 숨겨진 서브도메인을 전부 볼 수 있음

5. 결론

: DNSenum은 Zone Transfer를 먼저 시도해보고 안되면 사전대입으로 서브도메인을 캔다.

[비교]

	dnsenum	dnsrecon
기반 언어	Perl (오래됨)	Python (최신 트렌드)
동작	일단 다 찾음(자동화, 올인원)	원하는것만 선택하여 찾음 (정교한 옵션 제어)
출력 결과	XML 형식 지원	CSV, JSON 지원 (파싱하기 더 편함)
특수 기능	Whois 조회, C 클래스 스캔에 강점	DNSSEC Zone Walking , SRV 레코드 조회 강점
사용추천	많고 다양한 정보를 찾고 싶을때	특정 공격(AXFR 만, Brute Force 만)을 구현할때

[로그]

dnsenum으로 **Brute Force**를 했을 때 (**NXDOMAIN Log**)

사전 대입 공격을 하면 "없는 도메인"을 엄청나게 많이 물어봄. => 거절(**Denied**) 로그가 폭주

```
Oct 25 10:10:01 ns1 named[1234]: client 192.168.10.5#... (admin1.site.com): query (cache)
'admin1.site.com/A/IN' denied
```

```
Oct 25 10:10:01 ns1 named[1234]: client 192.168.10.5#... (admin2.site.com): query (cache)
'admin2.site.com/A/IN' denied
```

... (1초에 수백 줄 찍힘)

- 해석: 같은 놈(192.168.10.5)이 1초 동안 수백 번 이상한 걸 물어봄. -> **Brute Force** 공격 의심!

로그가 보이지 않는 이유

: 사전 대입 공격으로 인한 "없는 도메인" 쿼리 거절(**Denied**) 로그는 보이지 않는 이유는 **BIND(named)**의 기본 로깅 설정 때문이다.

(기본적으로 **BIND**는 서버 부하를 줄이기 위해 모든 들어오는 쿼리(특히 실패한 쿼리)를 상세히 기록하지 않는다.)

dnstenum으로 존 전송을 시도했을 때 (**AXFR Log**)

```
Nov 25 12:17:05 localhost.localdomain named[1043085]: client @0x7f31cc060d08 172.16.27.50#46545 (woo.com): transfer of 'woo.com/IN': AXFR started (serial 25091801)
```

```
Nov 25 12:17:05 localhost.localdomain named[1043085]: client @0x7f31cc060d08 172.16.27.50#46545 (woo.com): transfer of 'woo.com/IN': AXFR ended: 1 messages, 11 records, 276 bytes, 0.001 secs (276000 bytes/sec) (serial25091801)
```

- 해석: 172.16.27.50이 ****AXFR(존 전송)****을 시작(**started**)했고, 끝냈다(**ended**). -> 탈취 완료

```
Nov 25 12:04:24 localhost.localdomain named[1043085]: client @0x7f31cc065af8 172.16.27.50#34267  
(woo.com): transfer of 'woo.com/IN': AXFR started (serial 25091801)  
Nov 25 12:04:24 localhost.localdomain named[1043085]: client @0x7f31cc065af8 172.16.27.50#34267  
(woo.com): transfer of 'woo.com/IN': AXFR ended: 1 messages, 11 records, 276 bytes, 0.001 secs (  
276000 bytes/sec) (serial 25091801)  
Nov 25 12:06:13 localhost.localdomain named[1043085]: client @0x7f31d42acdc8 172.16.27.50#39831  
(woo.com): transfer of 'woo.com/IN': AXFR started (serial 25091801)  
Nov 25 12:06:13 localhost.localdomain named[1043085]: client @0x7f31d42acdc8 172.16.27.50#39831  
(woo.com): transfer of 'woo.com/IN': AXFR ended: 1 messages, 11 records, 276 bytes, 0.001 secs (  
276000 bytes/sec) (serial 25091801)
```